

Misconfiguration Catalogue

A controlled security assessment of the Azure 3-Tier Reference Workload — identifying, classifying, and remediating infrastructure misconfigurations across five security domains.

ASSESSMENT TOOL Prowler v5.31.1	SCAN DATE 27 June 2026
CLOUD PLATFORM Microsoft Azure	SUBSCRIPTION Azure subscription 1
WORKLOAD 3-Tier Reference Architecture	COMPLIANCE FRAMEWORK CIS Azure Benchmark v5.0
IAC TOOL Terraform (azurerm ~> 3.110)	DOCUMENT CLASSIFICATION Confidential

127

TOTAL FINDINGS

90

FAILED CHECKS

37

PASSED CHECKS

12

CATALOGUED MCS

1. Executive Summary

This catalogue documents a structured security assessment of a Terraform-provisioned Azure 3-tier reference workload consisting of an App Service web tier, Azure SQL Database, Blob Storage, Key Vault, and supporting networking infrastructure. The Prowler open-source CSPM tool (v5.31.1) was used to conduct an API-driven, agentless audit of the live subscription against the CIS Azure Benchmark v5.0 and 16 additional compliance frameworks.

The baseline scan produced **127 findings across 42 resources**, with **90 failures (70.9%)** confirming that even a carefully designed Infrastructure-as-Code deployment carries a meaningful residual attack surface. Twelve misconfigurations were selected and catalogued spanning five security domains: IAM/Identity, Storage, Networking, Encryption, and Logging/Monitoring. Of these twelve, **seven were identified as already present in the baseline scan** (proving real-world detection capability) and five are deliberately introduced as controlled test cases to validate Prowler's detection coverage and demonstrate end-to-end remediation.

Baseline Scan Overview

Metric	Value	Metric	Value
Prowler Version	5.31.1	Resources Scanned	42
Subscription	Azure subscription 1	Total Findings	127
Scan Date	27 June 2026	Pass / Fail	37 PASS / 90 FAIL
Auth Method	Service Principal (sp-env-auth)	Pass Rate	29.1%

Catalogue Design Methodology

- 1

Baseline Scan (Scan A)

Prowler executed against the live subscription with no deliberate misconfigurations. All 90 failures documented as the starting posture. This is the "Before" state.
- 2

Catalogue Classification

12 findings selected and divided: Already Present (7, detected in Scan A natively) vs. Introduced (5, new misconfigs applied via `misconfig.tf` Terraform branch).
- 3

Misconfiguration Branch (Scan B)

5 new misconfigurations applied via Terraform, re-scan run. Delta against Scan A proves Prowler detection capability.
- 4

Remediation + Re-scan (Scan C)

All 12 misconfigurations fixed in Terraform. Final scan demonstrates measurable posture improvement and closes the loop.

Domain Coverage Summary

#	Security Domain	Misconfigs	Already Present	Introduced	Prowler Detectable
1	IAM / Identity	3	1	2	2 of 3
2	Storage	3	3	0	3 of 3
3	Networking	2	1	1	2 of 2
4	Encryption / TLS	2	0	2	2 of 2

5	Logging / Monitoring	2	2	0	2 of 2
TOTAL		12	7	5	11 of 12

2. Misconfiguration Catalogue

Each entry includes: unique ID, security domain, severity, Prowler check ID, baseline status, MITRE ATT&CK/CIS mapping, attack scenario, Terraform root cause, and remediation code.

Already Present

— Detected in Prowler Baseline Scan A

Newly Introduced

— Added via misconfig.tf branch

Partial

— Partially detected

DOMAIN 1 — IAM / IDENTITY

MC-01 | keyvault_recoverable

HIGH

Key Vault Purge Protection Disabled

Already Present

AFFECTED RESOURCE

ref3tierkv7mog1c (Key Vault)

CIS AZURE V5.0 CONTROL

3.3 — Ensure Key Vault is Recoverable

BASELINE PROWLER STATUS

FAIL (detected in Scan A)

PROWLER CHECK ID

keyvault_recoverable

MITRE ATT&CK

T1485 — Data Destruction

IMPACT RATING

HIGH — Irreversible secret deletion possible

ATTACK SCENARIO & RATIONALE

Without purge protection, a compromised identity with Key Vault Contributor rights (or the operator themselves making an error) can permanently delete the vault and all its secrets in a single API call — bypassing the soft-delete retention window. In a production scenario where the SQL password and other credentials live in Key Vault, permanent deletion constitutes a full credential destruction event causing service outage and potential data breach (if attackers exfiltrate secrets first, then purge to erase evidence).

TERRAFORM ROOT CAUSE

```
# keyvault.tf — current (misconfigured)
resource "azurerm_key_vault" "main" {
  purge_protection_enabled = false # VULNERABILITY
  soft_delete_retention_days = 7
}
```

Remediation: Set purge_protection_enabled = true in the Key Vault resource block. Note: this change is irreversible for the vault's lifetime — the vault cannot be hard-deleted for the retention period (minimum 7 days). This is the expected secure configuration per CIS and Microsoft baseline.

Key Vault RBAC Disabled — Permissive Access Policy Applied

Newly Introduced

AFFECTED RESOURCE

ref3tierkv7mog1c (Key Vault)

CIS AZURE V5.0 CONTROL

3.1 — Use RBAC for Key Vault Authorization

BASELINE PROWLER STATUS

PASS (currently) — will FAIL after introduction

PROWLER CHECK ID

keyvault_rbac_enabled

MITRE ATT&CK

T1078 — Valid Accounts / Privilege Escalation

IMPACT RATING

HIGH — Bypasses role-based least-privilege model

ATTACK SCENARIO & RATIONALE

The older access-policy model grants permissions per identity at the vault level rather than at specific secret/key scope. An access policy granting full secret permissions (Get, List, Set, Delete, Purge) to the operator's identity means any credential compromise — phishing, token theft, or CI/CD pipeline breach — immediately yields full control over every secret in the vault. RBAC restricts this to named roles with specific scopes, so a "Secrets User" on one secret cannot touch others. Disabling RBAC also removes Conditional Access and PIM (Privileged Identity Management) enforcement from vault access, eliminating just-in-time controls.

TERRAFORM ROOT CAUSE (MISCONFIG.TF)

```
# INTRODUCED misconfiguration
resource "azurerm_key_vault" "main" {
  enable_rbac_authorization = false # VULNERABILITY: was true
}
resource "azurerm_key_vault_access_policy" "wide_open" {
  secret_permissions = ["Get", "List", "Set", "Delete", "Purge"]
}
```

Remediation: Set `enable_rbac_authorization = true` and remove access policy resources. Use scoped role assignments: "Key Vault Secrets Officer" for the deployer, "Key Vault Secrets User" for the web app managed identity — as defined in the original `keyvault.tf`.

Key Vault Secret Has No Expiration Date

Already Present

AFFECTED RESOURCE

sql-admin-password secret in ref3tierkv7mog1c

CIS AZURE V5.0 CONTROL

3.4 — Ensure Secret Expiration is Set

BASELINE PROWLER STATUS

FAIL (detected in Scan A)

PROWLER CHECK ID

keyvault_rbac_secret_expiration_set

MITRE ATT&CK

T1552.001 — Credentials in Files (long-lived)

IMPACT RATING

MEDIUM — Indefinitely valid credential exposure risk

ATTACK SCENARIO & RATIONALE

A secret without an expiration date is a permanently valid credential. If the SQL admin password is leaked (e.g., via audit logs, memory dumps, or a compromised pipeline), it remains usable indefinitely unless manually rotated. NIST 800-63B and CIS mandate a maximum credential lifetime to limit the window of exposure. In this deployment, the `sql-admin-password` secret was written with no `expiration_date` attribute, leaving it valid forever.

Remediation: Add `expiration_date = timeadd(timestamp(), "2160h")` (90 days) to the `azurerm_key_vault_secret` resource. Implement automated rotation via Azure Key Vault + Azure Automation or Logic Apps.

MC-04 | storage_account_key_access_disabled

HIGH

Storage Account Shared Key Access Enabled

Already Present

AFFECTED RESOURCES

ref3tierst7mog1c and tfstatevignesh001

CIS AZURE V5.0 CONTROL

7.2 — Disable Shared Key Authorization

BASELINE PROWLER STATUS

FAIL on BOTH storage accounts (Scan A)

PROWLER CHECK ID

storage_account_key_access_disabled

MITRE ATT&CK

T1530 — Data from Cloud Storage

IMPACT RATING

HIGH — Static key bypasses Azure AD and Conditional Access

ATTACK SCENARIO & RATIONALE

Shared access keys are 512-bit static secrets that provide full control over all storage account operations — no Azure AD authentication, no Conditional Access policies, no MFA, no PIM. A key stolen from application config, environment variables, CI/CD pipeline secrets, or memory dumps grants an attacker permanent, unchecked access to all blobs and containers. This defeats the Managed Identity architecture built into the web tier. Both storage accounts — the app data store and the Terraform state backend — were failing this check in the baseline, meaning the state file containing all infrastructure details was also accessible via static key.

TERRAFORM ROOT CAUSE

```
# storage.tf – attribute omitted (Azure default = enabled)
resource "azurerm_storage_account" "main" {
  # shared_access_key_enabled not set – defaults to true
}
```

Remediation: Explicitly set `shared_access_key_enabled = false` on all storage accounts. Ensure the web app's managed identity uses Azure AD-based access (already configured via Role Assignment). The Terraform state backend requires a separate mitigation — use SAS token with limited scope or migrate to managed identity auth for the backend.

Storage Account Allows Blob Public (Anonymous) Access

Already Present

AFFECTED RESOURCE

ref3tierst7mog1c (application storage)

CIS AZURE V5.0 CONTROL

7.1 — Ensure Public Access is Disabled

BASELINE PROWLER STATUS

FAIL on app storage account (Scan A)

PROWLER CHECK ID

storage_blob_public_access_level_is_disabled

MITRE ATT&CK

T1530 — Data from Cloud Storage Object

IMPACT RATING

HIGH — Any container can be made publicly readable

ATTACK SCENARIO & RATIONALE

When `allow_nested_items_to_be_public` is not explicitly set to `false`, any container within the account can have its access level changed to "Blob" or "Container" by any identity with Storage Contributor rights — enabling unauthenticated internet read access to all blobs in that container. This is a common data-breach vector: attackers enumerate storage accounts, find a publicly accessible container, and exfiltrate sensitive data without needing any credentials. Although the `app-data` container was created with `private` access, the account-level flag was not set, meaning a single container reconfiguration creates a public data leak.

Remediation: Add `allow_nested_items_to_be_public = false` to the storage account resource. This is an account-level guard that prevents any container from ever being set to public access regardless of per-container settings.

Storage Account Default Network Access Rule Set to Allow

Already Present

AFFECTED RESOURCES

ref3tierst7mog1c and tfstatevignesh001

CIS AZURE V5.0 CONTROL

7.4 — Ensure Default Network Access is Deny

BASELINE PROWLER STATUS

FAIL on BOTH storage accounts (Scan A)

PROWLER CHECK ID

storage_default_network_access_rule_is_denied

MITRE ATT&CK

T1190 — Exploit Public-Facing Application

IMPACT RATING

HIGH — Storage publicly reachable over internet

ATTACK SCENARIO & RATIONALE

The Azure storage account default network access rule of "Allow all networks" means the storage REST API endpoint is reachable from any IP on the internet. While authentication is still required, this dramatically increases the attack surface: brute-force attacks against SAS tokens, credential stuffing with leaked keys, and exploitation of future Azure storage vulnerabilities all require reachability. The correct posture is default-deny with explicit allow rules for trusted VNets and Azure services — defence-in-depth that contains the blast radius of any credential compromise.

Remediation: Add a `network_rules` block to both storage accounts with `default_action = "Deny"`, `bypass = ["AzureServices"]`, and an explicit `virtual_network_subnet_ids` entry for the web-integration-subnet. This restricts access to trusted subnets only.

MC-07 | `network_subnet_nsg_associated`

HIGH

Web-Integration Subnet Has No NSG — Uncontrolled Outbound Path

Already Present

AFFECTED RESOURCE

`web-integration-subnet` in `ref3tier-dev-vnet`

CIS AZURE V5.0 CONTROL

6.2 — Ensure NSG on Every Subnet

BASELINE PROWLER STATUS

FAIL — subnet without NSG detected in Scan A

PROWLER CHECK ID

`network_subnet_nsg_associated`

MITRE ATT&CK

T1071 — Application Layer Protocol / Lateral Movement

IMPACT RATING

HIGH — Uncontrolled network path from App Service to VNet

ATTACK SCENARIO & RATIONALE

The App Service VNet integration subnet exists to route outbound traffic from the web tier into the VNet — enabling reach to the SQL private endpoint. Without an NSG on this subnet, outbound traffic from the App Service is unconstrained: if the web application is compromised (e.g., RCE via a vulnerable container), an attacker can pivot laterally to any resource in the VNet, including the data subnet and SQL private endpoint. An NSG on the integration subnet should restrict egress to only port 1433 toward the data subnet CIDR, enforcing least-privilege network flow.

TERRAFORM ROOT CAUSE

```
# network.tf – integration subnet created with no NSG association
resource "azurerm_subnet" "web_integration" {
  # delegation block present, but no NSG association resource
}
# Missing: azurerm_network_security_group + azurerm_subnet_network_security_group_association
```

Remediation: Create `azurerm_network_security_group.web_integration` allowing only port 1433 egress to 10.0.2.0/24 (data subnet) and port 443 to internet (for App Service management). Associate via `azurerm_subnet_network_security_group_association`.

SQL Server Public Network Access Re-Enabled

Newly Introduced

AFFECTED RESOURCE

ref3tier-dev-sql-7mog1c (Azure SQL Server)

CIS AZURE V5.0 CONTROL

6.5 — Ensure SQL Public Access is Disabled

BASELINE PROWLER STATUS

PASS (currently) — will become CRITICAL FAIL

PROWLER CHECK ID

sqlserver_unrestricted_inbound_access

MITRE ATT&CK

T1190 — Exploit Public-Facing Application

IMPACT RATING

CRITICAL — Direct internet exposure of production database

ATTACK SCENARIO & RATIONALE

Re-enabling `public_network_access_enabled = true` exposes the SQL server's TDS endpoint (port 1433) directly to the internet, completely nullifying the private-endpoint isolation architecture. Combined with the SQL admin password (recoverable from Key Vault if the vault's RBAC is also disabled via MC-02), an attacker has a direct, authenticated path to the database from any internet-connected host. This is the single highest-impact misconfiguration in this catalogue — it converts a well-isolated database tier into a directly exploitable internet asset.

TERRAFORM ROOT CAUSE (MISCONFIG.TF)

```
# INTRODUCED misconfiguration
resource "azurerm_mssql_server" "main" {
  public_network_access_enabled = true # CRITICAL VULNERABILITY — was false
}
```

Remediation: Immediately set `public_network_access_enabled = false`. Verify private endpoint still resolves correctly via `az sql server show --query publicNetworkAccess`. This should be run and verified within the same Terraform apply session — do not leave this misconfiguration active overnight.

MC-09 | `app_minimum_tls_version_12`

MEDIUM

App Service TLS Version Downgraded to 1.0

Newly Introduced

AFFECTED RESOURCE

`ref3tier-dev-app-7mog1c` (App Service)

CIS AZURE V5.0 CONTROL

9.2 — Ensure Minimum TLS Version is 1.2

BASELINE PROWLER STATUS

PASS (currently) — will become FAIL after introduction

PROWLER CHECK ID

`app_minimum_tls_version_12`

MITRE ATT&CK

T1557 — Adversary-in-the-Middle

IMPACT RATING

MEDIUM — Session interception via protocol downgrade

ATTACK SCENARIO & RATIONALE

TLS 1.0 and 1.1 are deprecated protocols with known cryptographic weaknesses including BEAST (Browser Exploit Against SSL/TLS), POODLE (Padding Oracle On Downgraded Legacy Encryption), and CRIME. Allowing TLS 1.0 opens the web tier to protocol downgrade attacks where a network adversary forces a client to negotiate the weakest supported version. In a financial or healthcare context, this would directly violate PCI-DSS Requirement 6.5.4 and HIPAA Technical Safeguard requirements. The App Service baseline correctly enforced TLS 1.2 — this misconfiguration deliberately removes that protection.

TERRAFORM ROOT CAUSE (MISCONFIG.TF)

```
# INTRODUCED misconfiguration
resource "azurerm_linux_web_app" "web" {
  site_config {
    minimum_tls_version = "1.0" # VULNERABILITY - was "1.2"
  }
}
```

Remediation: Restore `minimum_tls_version = "1.2"` in the `site_config` block. Consider upgrading to "1.3" if all client environments support it — TLS 1.3 eliminates the handshake vulnerabilities present in 1.2.

SQL Server Minimum TLS Version Downgraded to 1.0

Newly Introduced

div>

AFFECTED RESOURCE

ref3tier-dev-sql-7mog1c (Azure SQL Server)

PROWLER CHECK ID

sqlserver_recommended_minimal_tls_version

CIS AZURE V5.0 CONTROL

6.3 — Ensure SQL Server TLS is Set to Latest

MITRE ATT&CK

T1557 — Adversary-in-the-Middle

BASELINE PROWLER STATUS

PASS (currently) — will become FAIL after introduction

IMPACT RATING

MEDIUM — Database transport layer exposed to downgrade

ATTACK SCENARIO & RATIONALE

While the SQL server is reached via private endpoint (meaning it is not internet-accessible in the hardened configuration), TLS still protects the in-transit channel between the App Service and the SQL server within the VNet. Allowing TLS 1.0 at the SQL server level means a man-in-the-middle position within the VNet (e.g., an attacker who has compromised another VM or the App Service itself) could force a downgrade negotiation and intercept or tamper with query results. This is a defense-in-depth failure — even private channels should enforce modern TLS.

Remediation: Restore `minimum_tls_version = "1.2"` on the `azurerm_mssql_server` resource. Verify with `az sql server show --query minimalTlsVersion`.

MC-11 | `keyvault_logging_enabled + monitor_diagnostic_settings_exists + sqlserver_auditing_enabled`

HIGH

Already Present

No Diagnostic Logging Configured on Any Resource

AFFECTED RESOURCES

Key Vault, SQL Server, App Service, Subscription

PROWLER CHECK IDS (4 CHECKS)

`keyvault_logging_enabled` ,
`monitor_diagnostic_settings_exists` ,
`sqlserver_auditing_enabled` ,
`app_http_logs_enabled`

CIS AZURE V5.0 CONTROLS

3.5, 5.1, 5.2, 5.3, 5.4

MITRE ATT&CK

T1562.008 — Impair Defenses: Disable Cloud Logs

BASELINE PROWLER STATUS

FAIL on ALL 4 checks (detected in Scan A)

IMPACT RATING

HIGH — Zero visibility into security events

ATTACK SCENARIO & RATIONALE

Without diagnostic settings, Azure resources produce no audit trail. An attacker who has gained access can operate without any log evidence being generated: secret reads from Key Vault are unrecorded, SQL query execution is untracked, App Service HTTP requests are unlogged, and subscription-level administrative actions generate no audit stream. This directly violates the NIST CSF "Detect" and "Respond" functions. In incident response, absence of logs makes forensic attribution impossible and prevents detection of lateral movement, data exfiltration, or privilege escalation. The Terraform codebase contains zero `azurerm_monitor_diagnostic_setting` resources — a systematic omission across the entire workload.

TERRAFORM ROOT CAUSE

```
# MISSING from all .tf files – no diagnostic settings anywhere
# Required: azurerm_log_analytics_workspace + azurerm_monitor_diagnostic_setting
# for: Key Vault, SQL Server, App Service, Subscription activity log
```

Remediation: Create one `azurerm_log_analytics_workspace`, then add `azurerm_monitor_diagnostic_setting` for Key Vault (AuditEvent category), SQL Server (SQLSecurityAuditEvents), App Service (AppServiceHTTPLogs, AppServiceConsoleLogs), and a subscription-level diagnostic setting (Administrative, Security, Alert, Policy categories). Also enable `azurerm_mssql_server_extended_auditing_policy` for SQL.

NSG Flow Logs Disabled — Network Traffic Invisible

Already Present

AFFECTED RESOURCES

NetworkWatcher_centralindia, all NSGs in VNet

CIS AZURE V5.0 CONTROL

6.6 — Ensure NSG Flow Logs are Enabled and Sent

BASELINE PROWLER STATUS

FAIL on both flow-log checks (detected in Scan A)

PROWLER CHECK IDS

network_flow_log_captured_sent ,
network_watcher_enabled

MITRE ATT&CK

T1046 — Network Service Discovery / T1562.008

IMPACT RATING

HIGH — Network-layer attacks undetectable post-compromise

ATTACK SCENARIO & RATIONALE

NSG flow logs record all accepted and denied network flows through each Network Security Group, providing the network-layer audit trail. Without them, a port-scan, lateral movement attempt, data exfiltration over unusual ports, or C2 beaconing within the VNet produces no detectable signal. Network Watcher (the Azure resource that manages flow logging) was not enabled in the centralindia region in the baseline scan, meaning flow logging infrastructure does not even exist yet. This is a fundamental network visibility gap — the equivalent of having no network firewall logs on a corporate perimeter.

Remediation: Enable Network Watcher via azurerm_network_watcher resource. Then add azurerm_network_watcher_flow_log for each NSG, pointing to a storage account for raw logs and a Log Analytics workspace for Traffic Analytics. Set retention to 90+ days per CIS requirement.

Prowler Tool Gap Note: Prowler detected the absence of flow logs (MC-12) and the Network Watcher enablement gap, but cannot detect whether a specific NSG rule allows port 1433 from 0.0.0.0/0 — that NSG-level SQL port check is not present in Prowler's current Azure check library (Prowler checks SQL *firewall rules*, not NSG rules). This represents a supplementary manual review requirement and should be noted in your capstone report as a tool limitation requiring compensating controls.

3. Master Misconfiguration Summary

ID	Domain	Title	Severity	Prowler Check ID	Baseline Status	CIS v5.0
MC-01	IAM	Key Vault purge protection disabled	HIGH	keyvault_recoverable	Already Present	3.3
MC-02	IAM	Key Vault RBAC disabled	HIGH	keyvault_rbac_enabled	Introduced	3.1
MC-03	IAM	Secret has no expiration date	MEDIUM	keyvault_rbac_secret_expiration_set	Already Present	3.4
MC-04	Storage	Shared key access enabled	HIGH	storage_account_key_access_disabled	Already Present	7.2
MC-05	Storage	Blob anonymous public access allowed	HIGH	storage_blob_public_access_level_is_disabled	Already Present	7.1
MC-06	Storage	Default network access rule is Allow	HIGH	storage_default_network_access_rule_is_denied	Already Present	7.4
MC-07	Networking	Integration subnet missing NSG	HIGH	network_subnet_nsg_associated	Already Present	6.2
MC-08	Networking	SQL public network access re-enabled	CRITICAL	sqlserver_unrestricted_inbound_access	Introduced	6.5
MC-09	Encryption	App Service TLS downgraded to 1.0	MEDIUM	app_minimum_tls_version_12	Introduced	9.2
MC-10	Encryption	SQL Server TLS downgraded to 1.0	MEDIUM	sqlserver_recommended_minimal_tls_version	Introduced	6.3
MC-11	Logging	No diagnostic settings on any resource	HIGH	keyvault_logging_enabled + 3 others	Already Present	3.5, 5.1-5.4

MC-12	Logging	NSG flow logs disabled	HIGH	network_flow_log_captured_sent	Already Present	6.6
-------	---------	------------------------	------	--------------------------------	-----------------	-----

Severity Distribution

Severity	Count	% of Catalogue	Risk Statement
CRITICAL	1	8.3%	Direct internet exposure of production database
HIGH	9	75%	Data exfiltration, lateral movement, audit evasion
MEDIUM	2	16.7%	Protocol downgrade, indefinite credential exposure

Scan Methodology & Expected Outcomes

Scan	State	Expected FAILs	Purpose
Scan A — Baseline	Original Terraform (hardened)	90 (actual)	Establish pre-misconfiguration posture
Scan B — Vulnerable	misconfig.tf applied (MC-02, 08, 09, 10 + MC-01 documented)	~94 (4 new FAILs)	Prove Prowler detection capability
Scan C — Remediated	All 12 MCs fixed in Terraform	<78 (target)	Demonstrate measurable posture improvement